

D832 Case Study 5: GlobalBiz Solutions Inc.

1. General Company Description

Industry and Purpose

GlobalBiz Solutions Inc. (GBS) operates within the business technology and office supply industry. It specializes in retailing enterprise software licensing, office supplies, and administrative support services to organizations worldwide. GBS is a publicly traded corporation listed on the S&P 500.

Location

The company's headquarters is in San Francisco, California. It also operates major subsidiaries throughout the European Union and Singapore, handling a significant volume of international data processing and cross-border data transfers.

Size

GBS employs over 10,000 people across 25 global offices. It has data centers in the U.S., Europe, and Asia to meet both compliance and customer needs for data residency and privacy laws.

Business or Entity Interactions

GBS works heavily in the business-to-business sector, providing software licensing, office supplies, and administrative support to Fortune 500 companies. The company also has partnerships with organizations across many industries that rely on its products and services.

2. Current Cybersecurity Workforce Structure

Monitoring and Response Staff

The Security Operations Center (SOC), based in the U.S., monitors real-time threats. The center is staffed during regular business hours only, excluding nights, weekends, and holidays. Its international regions rely on an automated alerting system. Network administrators sometimes respond to these alerts, which is outside their primary responsibilities but necessitated by the lack of regional security staff.

Compliance Staff

The Compliance Department is small and lacks resources, consisting of two employees who oversee U.S. compliance activities. International compliance, particularly in emerging markets, is handled on an ad hoc basis by regional legal teams.

Outsourcing of Services

GBS outsources most of its infrastructure maintenance to third-party providers. This contract has been in place for over 10 years, and the company trusts the provider to maintain regulatory compliance.

3. Types of Information Managed

- **personally identifiable information (PII)** of users (clients and employees)
- **financial data** related to banking transactions and credit card processing
- **protected health information (PHI)** for healthcare clients
- **international office data**, often transmitted across borders



Protected Systems

GBS has several systems that process sensitive data; however, data transmission between international offices occasionally occurs over unencrypted protocols due to legacy systems in international offices, latency, and the lack of a key management solution.

4. Established Policies, Procedures, and Governance**Password Policy**

The GBS password policy requires all passwords to be changed every 180 days and does not allow passwords to be reused. The policy includes no complexity requirements, but multifactor authentication (MFA) is encouraged where applicable. The policy identifies an exemption that allows service account passwords to remain unchanged since they are used to run application pools for corporate web servers.

Network Security Policy

GBS has a generic network security policy that explains password authentication, backup operations, and how access is granted to network resources. Management is currently seeking feedback on an amendment to account for data encryption and system hardening.

Data Loss Prevention Procedures

GBS does not have a comprehensive data loss prevention (DLP) solution in place but has published a standard operating procedure (SOP) that identifies actions that should be taken to limit data loss. These actions include monitoring networks and searching open file shares.

Data Retention Policy

The GBS data retention policy requires all collected data, regardless of classification, to be stored in an enterprise repository in the California data center. The policy recommends the disposition of all information after four years.

Personnel Security Procedures

The current personnel security SOP requires all employees and contractors to self-report any legal issues, including criminal offenses, lawsuits, and bankruptcies. The document assumes that HR has vetted all new hires and allows for the creation of network accounts on the first day of employment. The organization performs internet usage monitoring in response to HR requests and maintains a robust camera system across all locations.

5. Security Goals and Objectives

- Maintain system availability for all locations
- Prioritize business continuity to prevent disruptions to operations
- Comply with applicable laws and regulations
- Build a resilient and integrable cybersecurity posture
- Incorporate artificial intelligence considerations into current and future policies and procedures
- Proactively refine processes and practices to minimize the impact of security incidents
- Build an enterprise cybersecurity team with clearly defined roles and responsibilities



POST-INCIDENT REPORT 1: GlobalBiz Solutions Inc.

INCIDENT NAME**LOCATION**

Corporate Supply Chain Compromise

San Francisco/Singapore

SUMMARY

The SOC team received an automated alert related to anomalous behavior from a server belonging to a toner cartridge vendor in Singapore that synchronizes with an internal corporate database to update inventory levels. SOC staff confirmed data transmissions from the internal server, which should only receive data from the vendor asset. After confirming sensitive data and credential egress, the transfer of Cobalt Strike and Mimikatz tools from the vendor host was observed. The internal server was isolated, and the vendor was notified. The server was rebuilt, all passwords were reset, and the network connection has been closed. Toner cartridge sales are stalled, and local clients in Singapore are concerned with GlobalBiz security. An online report was made to Singapore authorities.

ROOT CAUSE

The company used generic bidirectional firewall rules for external connections and has no requirements for external vendors. The use of deprecated encryption protocols such as PPTP at international sites allowed credential discovery and theft.

LESSONS LEARNED

POST-INCIDENT REPORT 2: GlobalBiz Solutions Inc.

INCIDENT NAME

Executive Spear Phishing

LOCATION

San Francisco, CA

SUMMARY

The vice president for client relations (VPCR) received a message that appeared to originate from an international client regarding a refund on supplies that were purchased. The VPCR called the telephone number provided in the email and encountered a language barrier on the provided client website. The VPCR downloaded TeamViewer software to work with the client in rendering payment. The next morning, he reported being unable to access the purchase card account and received an email notification that the maximum corporate card limit of \$150,000 had been met. The SOC confirmed the initial email originated outside the corporate domain, requested a password change for the user, and initiated a dispute with the credit card company. The VPCR is unable to make purchases until a new card is received but is otherwise operational. No automated security alerts were noted.

ROOT CAUSE

An end user successfully downloaded and installed potentially unwanted software without detection. The external phishing email was not quarantined or moved out of the primary inbox, and corporate payment validation processes were not followed.

LESSONS LEARNED